明镜 · 权限与呈现

第五份产品定义 · 2026-09-29（**最后一块主体**） 这一份回答两件事： **① 谁能看到什么（多租户隔离 / 字段级权限 / 主播端边界 / 授权与隐私） ② 原型按业内专业标准要交付什么（七项交付物，逐项说清给谁、包含什么、什么算合格）** 依据：02/03/04 已定结论 + 点悦真实字段 + 《个人信息保护法》+《网络表演经纪机构管理办法》（文旅部） + 旧版明镜的隐私设计。

零、30 秒版

一句话结论：

> **权限的本质不是"给谁开什么功能"，是"让他只看该看的——而且他想漏也漏不出去"。 好的权限设计是"默认看不到，要才给"，不是"默认都看得到，再一个个关"。**

四个决定：

#	决定	一句话理由	影响什么商业结果
1	**多租户做"双保险"**：技术上一户一间，制度上"忘了加条件也漏不出去"	一次串号 = 所有客户流失 + 尽调污点	**数据安全是生死问题**（BP 10.1 原话）
2	**权限做到字段级**（不是"能不能看这张表"，是"哪几列给你看"）	财务之所以进不了飞书，原话是"涉及敏感数据，不适合多维表格承载"	财务、薪酬、保底**第一次能有系统**
3	**主播端只用一条规则**：只给他"关于他自己的 + 对他有用的"	03 已定：评级/去留/淘汰一个字不给。**这条规则能推到每个字段**	保住"站在主播这边"的立场
4	**交付分两个包：路演包给投资人，开发包给 IT**	两个读者的需求完全不同，混在一起两边都不满意	**投资人看得懂 + IT 做得出**

★ 一个有分量的额外发现（见第六节）：

> **直播公会有专门的行业法规**——《网络表演经纪机构管理办法》（文化和旅游部，2021）。 它规定经纪机构**必须**做四件事：**核实表演者身份 / 签订协议 / 约束表演者行为 / 加强教育培训。 这四件事里有三件，正好是明镜在做的功能。 所以明镜不只是"提效工具"——它同时是"合规工具"。 而"不合规会被罚"这件事，对公会老板比"提效"更硬。**

一、第一性原理：权限的本质是什么

想清楚一件事：权限设计里，"看不到"比"看得到"重要

大多数系统设计权限的思路是：**先假设大家都能看，再一个个关掉。**

这个思路一定是错的。 因为：

	"默认能看，再关"	**"默认看不到，要才给"**
漏掉一个	**不该看的看到了**（事故）	该看的看不到（提个工单就好）
出了问题	数据泄露、客户流失、尽调污点	有人抱怨一下
代价	**不可逆**	可逆

两种错误的代价完全不对称。所以必须选后者。

这就是本文件所有设计的出发点：

> **任何数据、任何字段，默认是谁都看不到的。 只有明确写了"谁能看"，才会被看到。**

两条推论

推论一：能看多大范围 = 岗位 × 职级（02 已定）

- **岗位**（11 个）决定"看到哪些功能"
- **职级**（4 级：本人 / 组长 / 总监 / 管理层）决定"看到多大范围"

推论二：敏感的东西不能用"范围"来管，得"点名"

主播的**联系电话、微信号、保底金额**——这些不是"组长就能看"，而是"**只有特定岗位能看**"。

范围管不了这种，必须一个一个点名。

所以明镜的权限有三层，不是两层：

层	**管什么**	**数量**
一层：公司	这家公司看不到那家公司的	每家公司一个空间
二层：范围	我这一级能看多大	**4 条规则**（本人/本组/本部门/全公司）
三层：字段	这一列给不给你	**按字段点名**

二、多租户：每家公司数据互不可见

先把问题说清楚（不用技术词）

明镜要同时服务 1,000 家公司。**A 公司的数据，B 公司绝对看不到。**

比喻：1,000 家公司的数据，像 1,000 户人家的东西，放在一个仓库里。

做法	像什么	风险
✕差的做法	所有东西堆一个大仓库，**每件货上贴个标签**"这是 A 公司的"。取货的人**要记得只看 A 公司的标签**	**记错了就出事**——一次疏忽，1,000 家客户的货全暴露
☑好的做法	**仓库分间，A 公司的人拿到的钥匙只能进 A 公司的房间**	就算他忘了自己是谁，**门也进不去**

结论：明镜做"双保险"

光有"钥匙"还不够，还要"门锁自己也认人"。 两道一起上：

保险	做什么	说人话
第一道：进门验	每次取数据，系统**自动**带上"我是哪家公司"	不是靠每个开发者记得写，是**系统自己加**
第二道：门锁验	数据库自己再检查一遍："这条数据是不是这家公司的？"	就算第一道漏了，**第二道也会把门锁死**

为什么必须两道：行业内真实发生过的教训——**"一个条件漏写，100 个客户的数据全暴露"。**

一道保险是"靠人不犯错"，两道保险是"人不犯错也不出事"。

> **这一条正是 02 铁律四（"机制要能自己检查自己"）在权限上的落地。** 我们不相信"每个人都记得写对"，我们相信"**写错了也漏不出去**"。

影响什么商业结果

如果只做一道
一次串号 → **1,000 家客户同时流失** → 前期投入全部打水漂（BP 10.1 原话）
尽调时讲不清楚 → **国资/产业资本这一关过不去**（BP 10.2 说这是"尽调必答题"）
而做双保险的成本：**很小的开发工作量**

这是整份产品方案里"投入产出比最高"的一件事之一。

三、字段级权限：同一张表，不同的列

为什么必须做这一层

证据就在点悦的真实数据里。点悦「主播管理表」有 **56 个字段**，其中这几个是敏感的：

> **联系电话 / 微信号 / 保底金额**

点悦自己的飞书方案里明确写：**这几个敏感字段，只有总经办（车十/樊总）能看。**

再看财务那一摊：

> 点悦方案的原话：「**财务工资核算：涉及敏感数据，不适合多维表格承载**」——结果就是：**财务到现在还在用 Excel。**

所以"字段级权限"不是为了好看，是为了解决一个真实问题：

角色	需要什么	不该看到什么
财务	主播的**等级、开播天数、流水、保底金额**（要算钱）	主播的**微信号、联系电话**（没用）
运营	主播的**表现数据、跟播记录**	主播的**保底金额**（是钱的事）
经纪人	候选人的**联系方式**（要联系）	别人的**面试评价**
妆造师	主播的**形象档案**	主播的**流水**

一个人要用的字段，往往只有那张表的十分之一。 给他全部，既是风险也是干扰。

怎么做（说人话）

给每个字段贴一个"谁能看"的标签。三种贴法：

标签	意思	例子
公开	全公司都能看	主播昵称、直播间编号、赛道
范围内	按职级走（本人/本组/本部门/全公司）	跟播记录、日报、面试记录
点名	只给列出来的岗位	**联系电话**（经纪人+运营）、**保底金额**（财务+管理层）、**评级**（对应岗

		位+管理层)

一个字段只能贴一个标签，贴完就是规则，不用每次再想。

> **注意**：标签是**客户自己可以改的**（02 决定 5：岗位可配置）。 因为**每家公司的敏感字段不一样**——A 公司觉得流水敏感，B 公司觉得年龄敏感。

影响什么商业结果

有了字段级权限	**没有**
财务第一次能有系统用（不用再退回 Excel）	财务永远在 Excel 里 → **少一个真实使用场景**
客户敢把敏感数据放进来	客户只敢放不痛不痒的数据 → **AI 学不到关键的东西**

四、权限矩阵（11 岗位 × 4 职级）

> **读法**：功能看**岗位**，范围看**职级**，敏感字段看**点名**。

4.1 范围规则（只有 4 条）

职级	**能看到的数据范围**
① 本人	只有自己经手的
② 组长	本组
③ 总监	本部门
④ 管理层	全公司

加一个开关：公司管理员（02 已定）——能开通账号、配部门岗位、配字段标签。默认给 CEO 或他指定的人。

4.2 功能 × 岗位矩阵

功能	**经纪**	**培训**	**运营**	**编导**	**视觉**	**妆造**	**行政**	**财务**	**管理层**
一句话查数据	✅	✅	✅	✅	✅	✅	✅	✅	✅
日报/周报/月报	✅	✅	✅	✅	✅	✅	✅	✅	✅

知识库	✅	✅	✅	✅	✅	✅	✅	✅	✅
主播档案（新建/编辑）	✅	—	✅	—	—	—	—	—	✅
7 段流水线推进	✅	✅	✅	—	✅	✅	—	—	✅
面试记录	✅	—	只看	—	—	—	—	—	只看
培训记录与进度	只看	✅	—	—	—	—	—	—	只看
跟播记录	—	—	✅	—	—	—	—	—	只看
复盘与下场建议	—	—	✅	—	—	—	—	—	只看
拍摄计划	—	—	发起	✅	—	—	—	—	只看
视觉调试记录 / 参数库	—	—	只看	—	✅	只看	—	—	只看
妆造预约与形象档案	—	✅	✅	—	只看	✅	—	—	只看
设备台账	—	—	—	—	—	—	✅	—	只看
采购台账	—	—	—	—	—	—	✅	—	只看
保底结算 / 分成汇总	—	—	只看	—	—	—	—	✅	✅
全公司看板 / 掉人归因	—	—	—	—	—	—	—	只看	✅
数据健康度	—	—	—	—	—	—	✅	—	✅

公司管理员设置	—	—	—	—	—	—	可选	—	✅
出图配额管理	—	—	—	—	—	—	—	✅	✅

"只看"的意思：能看到，不能改。 **舞蹈老师 和 商务**不在表里——02 已定：一期不做他们的专门功能，但账号存在。

★★ **一条读法补充（2026-10-03 补，原表有个坑）： 「7 段流水线推进」这一行的 ✅ 混了两种完全不同的东西**： | ✅的两种意思 | 谁属于这种 | 产品上长什么样 | |---|---|---| | ① **人来推进** | 经纪人 · 培训师 · 视觉调试 | 有**任务卡片**，有按钮（「联系并确认」「录入调试结果」…），**他提交了状态才往前走** | | ② **系统自动推进** | ★ **运营** · ★ **妆造师** | ★ **不生成任务、没有按钮、不需要提交结果** —— 状态由系统按时点自动走（妆造预约到点自动完成 / 运营录入数据后状态自动往前后走） | **为什么这一条必须写清**（不改就会做错）： **如果 IT 照着一个光秃秃的 ✅做，会做出「妆造师工作台上有个推进按钮」—— 而那正好和车总特意定的相反。** 妆造师那一侧的规矩是「**不看任务、不填表，只看排期表照表干活**」（见 `_数据 2.js` 妆造师条目 + 产品方案 APP-029）； 运营那一侧的规矩是「**日常跟播是运营主动录入，不生成员工任务**」（APP-006 / RULE-008）。 ★ **一句话**： **「这个人能不能推进」和「这个状态会不会推进」是两件事。** 前者是权限，后者是自动任务。**原表把它们写在了同一个 ✅里。**

4.3 敏感字段点名表

字段	谁能看	为什么
联系电话 / 微信号	经纪人 + 负责运营 + 管理层	要联系主播；**其他人不需要**
保底金额	财务 + 管理层 + 负责运营组长	算钱要用；**一线运营和妆造师不需要**
评级（5 个角色的评级）	打分的那个岗位 + 管理层 + 运营总监	各评各的；**不给主播看**（03 已定）
去留状态 / 流失原因 / 淘汰环节	对应岗位 + 管理层	**公司管理判断，不给主播**
复盘录音 / 录屏	负责运营 + 主播本人 + 管理层	声音是敏感信息，**不能全公司随便听**
分成比例 / 公司财务数据	财务 + 管理层	商业机密

★ **这张表是"默认看不到，要才给"最直接的体现**： 上面没列到的字段，**默认就是按"范围内"走**；敏感的一律点名，**没被点到的岗位看不到。**

五、主播端的字段边界（到字段级）

> 03 定了三条：**评级、去留状态、淘汰环节，一个字都不给主播看。** 这一节把它**落到每一个字段。**

5.1 一条规则管所有

> **主播只能看到"关于他自己的"+"对他有用的"。**

· 关于自己 + 有用 → **给**

· 关于自己 + **是公司的管理判断**（评级、去留、淘汰）→ **不给**

· **关于别人的 → 一律不给**（一个字段都不行）

这条规则的好处：不用逐个字段讨论。**任何一个字段，按这条规则都能判断出来。**

5.2 落实到点悦那张 56 字段的表

类别	字段（举例）	给主播吗
基本信息	昵称、主播编号、开播日期、班次、直播间	✅给
赛道与人设	赛道、人设定位	✅给
成长规划	当月目标、3 个月规划、完成百分比	✅**给**（★ 03 认定的第一优先）
复盘内容	复盘结论、下场建议	✅给
形象档案	妆造方案、美颜参数、灯光方案	✅给
数据趋势	自己的音浪/时长/涨粉趋势	✅给
联系方式	电话、微信号	⚠ **给**（是他自己的）
保底金额 / 签约信息	保底金额、签约状态、合同	⚠ **给**（他自己签的，他当然知道）
评级（5 个角色）	评级·面试官/培训老师/视觉部/运营组长/运营总监	❌**不给**
去留与流失	去留状态、流失日期、流失环节、流失原因、淘汰日期、淘汰环节、淘汰原因	❌**不给**
别人的一切	其他主播的任何字段	❌**不给**
公司视角字段	负责经纪人、经纪人组、疑似重复、备注	❌**不给**（是公司内部的归类）

⚠ **两个"给"要说明一下**： **保底金额和签约信息给主播看**——因为那是**他和公司谈好的**，不给他看反而奇怪（合同本来就该给他一份）。 **但"评级"不给**——因为那是**公司对他的评价**，不是他签的东西。 **这条界线可以一句话说清**：**"你签的、你该知道的，给你；公司怎么想你，不给你。"**

5.3 影响什么商业结果

这条边界守住了	**守不住**
主播觉得"这是我的助手"	主播觉得"这是公司监视我的"
ToC 才收得到钱（03 已论证）	ToC 收不到钱，明镜退化成内部工具

六、授权与隐私：三条红线落成流程

01 定了三条红线：**① 录音前必须告知并同意 ② 只在必要范围内可见 ③ 不用于训练对外提供的通用模型。** 这一节把它们**变成产品里真实存在的流程**——不是写个声明就完了。

6.1 一个前提：主播不是员工

这决定了授权怎么拿：

	员工	**主播（合作方）**
关系	雇佣	**合作**
授权怎么拿	入职时一并签	⚠ **必须单独拿，而且要能撤回**
能不能"默认同意"	可以（在职期间的工作安排）	**✕不行**

所以：给明镜加一个员工用的授权页是不够的，主播要有自己的一份。

6.2 授权页怎么写（这一条很容易做错）

先说一个会踩的坑：

如果授权页写得像法律文件，主播会直接划过去——等于没授权。 而且他心里会想"又是什么套路"。

所以授权页的要求是：短、说人话、能撤回。

建议的样子（主播第一次打开明镜时，一屏说完）：

我们要录下你和运营的复盘

录什么：下播后你和运营的复盘聊天
谁能看：你的运营、你自己、公司管理层
不拿来干什么：不对外、不训练通用的 AI 模型

你可以随时关掉这个授权 → 【现在关掉】

【我知道了，开始用】

四个要点：

要点	为什么
说人话（不写"个人信息处理"这种词）	说了他才会看；**看了才算同意**
说清"不拿来干什么"	这一条最能让主播放心（也是我们的自我约束）
能一键撤回	BP 10.2 说"可随时撤回"——**要真的能点，不是写在条款里**
录之前再提示一次	每次开录时给个明确提示（不是"签一次管一辈子"）

> **★ 这一条和铁律一（一个动作 ≤5 个字段）是同一个思路： 任何要人做决定的地方，都要简单到他能真的做决定。**

6.3 三条红线怎么落到产品里

红线	落到哪里
① 录音前告知并同意	首次一屏授权 + **每次开录前的提示**；主播端有"我的授权"页，能看能关
② 只在必要范围内可见	落到**字段级权限**（见 4.3）：复盘录音只有**负责运营 + 主播本人 + 管理层**能看到
③ 不训练通用模型	落到**技术说明**里（07 交付物）+ **合同条款**（《数据处理协议》）。**这一条要写进给 IT 的技术规格，不是写在 PPT 里**

6.4 ★ 一个有分量的发现：公会是有专门法规的

这一条值得单独说，因为它**改变了明镜的定位**。

我查了文旅部的《**网络表演经纪机构管理办法**》（2021 年施行）。**直播公会就是"网络表演经纪机构"，这个办法直接管它们。**

办法规定经纪机构必须做四件事：

#	法定要求	明镜在做的功能

1	**核实表演者身份**（面谈、视频通话等，确认身份信息一致，避免冒名顶替）	面试记录、身份核实留痕 ⚠ **可以补**
2	**必须与表演者签订协议**（书面形式；**电子数据也算法定书面形式**）	签约流程（点悦已有 14 天签约窗口 + 逾期提醒） ✅
3	**约束表演者行为**（明令禁止语言刺激、承诺返利、线下接触/交往等诱导打赏行为）	**违规红线知识库** ✅
4	**加强教育培训**（告知法律法规和职业道德规范，禁止违法违规内容、脏话连篇、与粉丝对骂）	**培训 SOP + 培训师功能** ✅

★ 结论：这四件事里有三件，正好是明镜已经在做的功能。

所以明镜的定位应该是两层，不是一层：

层	卖什么	对老板的价值
第一层：提效	一个人干十个人的活	**省钱**（少招人）
第二层：合规	法规要求做的事，系统里自带	**避险**（不合规会被罚）

为什么第二层更硬：

> **"省钱"是可以拖的——今年不省，明年再说。 "合规"是不能拖的——不做的后果是罚款、停业、上黑名单。**

而且办法里还有一条数字：

> **「网络表演经纪人员与所签约网络表演者人数比例原则上不低于 1:100」**

这条说明官方承认"一对多（1 个经纪人员对 100 个主播）"是这个行业的常态形态。

→ 对明镜"一个运营带 50 个"的目标是一个有力的旁证：这个行业本来就是一对多的。

另外一个可以直接用的内容源：

> 中国演出行业协会制定了《**网络表演（直播）内容百不宜手册**》和《**网络主播警示和复出管理规范**》。 **明镜的"违规红线知识库"应该直接以这些为指导**——这是权威内容源，不用我们自己编。
>
> **★ 这条要回填到融资材料**：见 `00_要回填到融资材料的发现.md`。

七、原型按业内专业标准要交付什么 ★

> **这是车总最关心的一块。** 这一节逐项说清：**给谁、包含什么、长什么样、什么算合格。**

7.1 第一性原理

> **每一项交付物存在的唯一理由，是"给某个特定的人解决某个特定的问题"。 没有明确读者的交付物 = 白做。**

所以先分读者。明镜有两拨读者，需求完全不同：

读者	他想知道什么	他的判断标准
投资人	"这东西是什么？能做出来吗？值多少钱？"	**6 分钟内能不能看懂**
IT 团队	"我照着这个，能不能做出第一版？"	**有没有说不清的地方**

所以交付物必须分成两个包，不能混。

7.2 包一：路演包（给投资人）

项	内容	状态
① **高保真可交互原型**（HTML）	双击就开、点哪都有反应、6 分钟走完核心动线	✅**已有**（`3_原型演示.html`，6 条动线）
② **一页纸摘要**	2 页，第一次接触就发	✅已有
③ **路演 Deck**	19 页，讲的时候用	✅已有

包一的合格标准（一句话）：

> **找一个完全不懂直播的人，让他自己点一遍，看他能不能说出"这是干什么的、为什么值钱"。 说得出来 = 合格。说不出来 = 不是他的问题，是我们的问题。**

包一要不要按这一版的产品方案更新？要。 具体差什么：

缺口	为什么该补
"掉人归因"那一屏（02 最大发现）	现在原型里没有——**而它比"省人力"更值钱**
"导入"那一屏	04 定的新策略，原型里体现不出来
"合规"那一层（第六节）	现在完全没有——**这是"避险"的故事，比"省钱"硬**
知识库 + 自动日报	交付总结里已经点出"行业地图列为核心功能，原型里

	却没有"

7.3 包二：开发包（给 IT 团队）—— 待做

02_原型设计.md 里已经把这个叫"**交付原型**"，并写明"**需要车总确认后再做**"。 **现在是该做的时候了**——因为产品定义已经清楚（01-05 五份文件就是它的原料）。

七项交付物，逐项说清：

#	交付物	给谁	解决什么问题	包含什么	什么算合格
①	**PRD**（产品需求文档）	IT 团队 + 产品	**"要做什么"**	每个功能：谁用、什么场景、做什么、**不做什么**、优先级	**每个功能都能答上"谁用、干什么、不做哪些"**；没有"待定"的功能
②	**用户流程图**	IT + **车总**	**"整个流程长什么样"**	**每个角色一条线**：从进门到目标达成的完整路径（11 个岗位各一条 + 主播一条）	**每条线上没有断点**——每一步都知道"下一步交给谁、带过去什么"
③	**任务流程图**	IT	**"一个操作分几步"**	关键操作（**不超过 10 个**）的步骤和分支	照着图能说出"点哪里、填什么、然后呢"
④	**信息架构**	IT	**"页面怎么组织"**	页面清单 + 导航结构 + 页面之间怎么跳	**能回答"我要做 X，要点几下"**
⑤	**高保真原型**	IT + 前端	**"做出来长什么样"**	每个页面的完整设计（不只是路演那 6 屏）	前端**不用再问"这个页面长什么样"**
⑥	**设计规范**	IT（前端）	**"做出来长得一样"**	颜色 / 字体 / 组件 / 间距 / 状态（正常/悬停/禁用/空）	**前端照着能做，不用自己发挥**
⑦	**技术说明**	IT	**"怎么做"**	AI 怎么接（04 的四档）/ 数据怎么存 / 接口怎么调（04 的第二节表）/ 权限怎么控（本文件）/ **成本约束**（04 第六节：	**一个新人工程师，只拿这套东西，能不能不问人就开始做**

				能用规则做的不用 AI）	

7.4 ★ 判断开发包合格与否的唯一标准

> **把一个新来的前端工程师叫过来，只给他这套东西，什么都不说。 如果他不用问人就能开始做——合格。 如果他来问你"这个页面长什么样""这个按钮点了会怎样""这个数据从哪来"——那就是我们没写清。**

这条标准的好处：车总不懂技术，但他**能判断"新人要不要问人"。**

不用他懂技术，就能验收这份东西做得好不好。

7.5 每项交付物"什么时候要"

时间	要什么	为什么这个顺序
现在（融资前）	包一（路演包）**补齐那 4 个缺口**	路演要用
融资到账后第 1 个月	**① PRD + ② 用户流程图 + ④ 信息架构**	这三样定"做什么、流程怎么走、页面怎么分"——**定完才能开工**
开工前	**③ 任务流程图 + ⑤ 高保真 + ⑥ 设计规范**	前端要照着做
开工同时	**⑦ 技术说明**	后端要照着做

> ★ **一个顺序上的判断**：**②用户流程图 比 ①PRD 更该先做。** 因为 PRD 是"一个一个功能"，流程图是"**整个业务怎么转**"。 **先有全景图，再写功能清单，才不会写完发现接不上。** （02 那节"6 个交接点"就是这个全景图的核心。）

八、对抗性审查（四种人）

投资人

#	问题	回答
1	**"多公司数据放一起，你不怕出事？"**	怕，所以做**双保险。我不打算说"我们很小心"——我要说"就算有人犯错，也漏不出去"。** 这两句话在尽调时是两个估值。
2	**"权限做这么细，开发量是不是很**	不大。**范围规则只有 4 条**（本人/本

	大？"	组/本部门/全公司），**不是 44 种组合。**字段只要贴一次标签，之后是规则在跑。**这就是 02 把"岗位"和"职级"分开的价值。**
3	**"交付这么多文档，是不是在拖时间？"**	反过来——**这是省时间。**判断标准就一条：**新人工程师不问人能不能开工。**能，就说明没有返工；不能，写再多也白写。

IT 负责人

#	问题	回答
1	**"权限太多，代码里怎么管？"**	**不要在业务代码里写权限判断。** 权限在**数据入口处统一做**（这就是第二节"第一道保险"）。业务代码只管干活，**不管谁能看。**
2	**"客户要加字段、改流程怎么办？"**	岗位和字段标签**都是客户可配的**（02 决定 5）。代码里不许写死——**旧版教训原话：「别在代码里写死角色」。**
3	**"AI 会不会看到不该看的数据？"**	**会，如果不管。** 所以：**④/05 定的字段级权限要管到 AI**——AI 去查数据时，**用它服务的那个人**的权限。**不能给它"全公司"的权限。**（这条要写进 ⑦ 技术说明）

公会老板

#	问题	回答
1	**"我员工会不会看到不该看的？"**	默认看不到。**而且你可以自己设哪一列给谁看**——每家公司的敏感点不一样，这个你自己定。
2	**"我主播要是知道我在给他评级，会不会闹？"**	**他不知道。** 评级、去留、淘汰环节——**一个字都不给主播看。**这条已经写死在产品里。
3	**"出了事是我的责任还是你的？"**	**数据是你的，你是数据的主人，明镜是替你保管的。** 所以：签《数据处理协议》，**不跨客户混用、不对外输出、不训练通用模型**（BP 10.2 已立框架）。

法务 ★ 本轮新增

#	问题	回答
1	**"主播的复盘录音，你们怎么拿的授权？"**	**单独拿，而且能撤回**（见 6.2）。主播是**合作方不是员工**，不能用"入职一并签"那套。首次一屏说人话的授权 + **每次开录前再提示一次。**
2	**"客户的数据，你们会不会拿去训练模型？"**	**不会训练对外提供的通用模型。** 这条同时落在三处：**合同条款 + 技术说明 + 产品设置。**写进 ⑦ 技术说明，不是写在 PPT 里。
3	**"主播是合作方，公司有权把主播的数据给明镜吗？"**	⚠ **这是本文件最需要法务确认的一条。** 我的理解是：**主播的数据要主播自己授权**（不能用公司协议代替），所以 6.2 那套授权是**直接对主播**做的。**但这条要法务出意见**——已列进"没解决的问题"。
4	**"一家公司出事，会不会牵连别家？"**	**不会。** 双保险（第二节）：每家公司一个独立空间 + 数据入口统一验。**一家的问题不会流到另一家。**
5	**"法规要求的那些事，你们产品里有吗？"**	**有，而且是最强的差异化**（见 6.4）。《网络表演经纪机构管理办法》要求经纪机构做的四件事，**三件正好是明镜的功能。这是"合规工具"的故事，比"提效工具"更硬。**

九、我已拍板的事项

#	决定	为什么这么定	影响什么商业结果
1	**权限原则：默认看不到，要才给**	两种错误代价不对称——"该看的没看到"可逆，"不该看的看到了"不可逆	不出不可逆的事故
2	**多租户做双保险**（进门验 + 门锁验）	行业真实教训："一个条件漏写，100 个客户数据全暴露"；**不能靠人记得**	**一次串号 = 1,000 家客户同时流失**
3	**权限分三层：公司 / 范围 / 字段**	敏感字段用"范围"管不了，必须点名	财务第一次能有系统；客户敢放关键数据

4	**范围规则只有 4 条**（本人/本组/本部门/全公司）	02 把岗位和职级分开的价值就在这——**44 种组合变成 4 条规则**	开发量降一个量级
5	**主播端一条规则：只给"关于他自己的 + 对他有用的"**	03 定的边界，这条能推到每个字段，不用逐个讨论	保住"站在主播这边"的立场 → ToC 收得到钱
6	**授权页要说人话、能一键撤回、每次开录再提示**	写得像法律文件 = 主播划过去 = **等于没授权**	授权是真的，尽调时站得住
7	**AI 的权限 = 它服务的那个人的权限**	不能给 AI"全公司"的权限——那是绕开所有权限的后门	权限体系不被 AI 破掉
8	**交付分两个包：路演包给投资人，开发包给 IT**	两个读者的需求完全不同	投资人看得懂 + IT 做得出
9	**开发包的验收标准：新人不问人就能开工**	车总不懂技术，但**能判断"新人要不要问人"**	不用懂技术也能验收
10	**先做用户流程图，再做 PRD**	先有全景图，再写功能清单，才不会写完发现接不上	少返工
11	**"合规"作为明镜的第二层定位**	《网络表演经纪机构管理办法》要求的四件事，三件是明镜的功能；**"不合规会被罚"比"提效省钱"更硬**	从"省钱"变成"省钱 + 避险"，客户更难拒绝

关于第 11 条要多说一句

这条是本轮最有商业价值的发现。

	只讲提效	**提效 + 合规**
客户为什么买	少招几个人	少招几个人 + **不被罚**
能不能拖	**能拖**（今年不省，明年再说）	**不能拖**（罚款、停业、黑名单）
在哪卖	跟运营总监聊	**跟老板聊**（合规是老板的事）
竞品好不好抄	好抄	**难抄**（要求产品里有真实的流程留痕）

建议把它写进路演材料——见 `00_要回填到融资材料的发现.md`。

十、这一轮没解决的问题

#	没解决	找谁 / 下一步
1	⚠ **主播数据的授权主体**：主播是合作方，公司有权把他的数据给明镜吗？还是必须主播自己授权？	**法务出意见**——这是本文件最需要法务确认的一条
2	《数据处理协议（DPA）》模板	法务起草（BP 10.2 已列为待办）
3	用户授权流程与隐私政策定稿	法务 + 产品
4	数据合规自查清单（对照《个人信息保护法》《数据安全法》逐条）	法务（BP 10.2 已列为待办）
5	**旧版的"匿名树洞"做不做**	**见下方说明**
6	多租户的具体技术实现（做到哪一档）	IT 团队（按第二节的"双保险"原则选型）
7	开发包七项交付物的分工与工期	产品 + IT，**融资到账后第 1 个月**
8	路演包要补的 4 个缺口	原型 + Deck 更新（见 7.2）
9	数据健康度面板的指标清单	05 的延伸，归到开发包

关于第 5 条：旧版的"匿名树洞"，做不做？

旧版明镜做过一个"匿名树洞"（主播匿名说心里话），设计得很硬：

> 独立数据表、**不可逆哈希 ID**、独立密钥加密、UI 层隐藏身份、三级预警（疑似/关注/紧急）、**"跨角色绝对隔离""数据写入时就隔离，不是视图层隐藏"**

我的判断：一期不做，但要把它的一条原则留下来。

	理由
为什么一期不做	① 点悦现在没有（飞书里没有这个）；② 它属于**最高敏感级数据**（心理/情绪），要专门的合规设计；③ 02 的原则是**"我们验证不了的角色/功能先不做"**
但要留下什么	**"数据写入时就隔离，不是视图层隐藏"**——这条原则对**多租户**和**字段级权限**同样适用，已经吸收进第二节和第三节
为什么它值得记着	旧版那份设计里有一句判断很准：「**树洞是主播信任的基石**」。**如果将来要给主播端加"深度"，这是一个方向**——但要等法务和产品一起设计

> **记进功能池第四档（以后做）。**

依据：① 内部：01/02/03/04 五份已定结论、点悦飞书真实字段与敏感字段标注、旧版明镜的隐私设计（树洞/权限矩阵/事件流隔离）；② 法规：《个人信息保护法》、《网络表演经纪机构管理办法》（文化和旅游部，2021，中国政府网）、中国演出行业协会《网络表演（直播）内容百不宜手册》；③ 行业：SaaS 多租户隔离实践。

凡需专业判断的（授权主体、合规边界），文中一律标"待法务确认"，没有替法务下结论。

陕西驭界科技有限公司 · 2026 年 9 月